

TLP:CLEAR

INCIDENT REPORT

Credential-harvesting campaign: polymorphic phishing kit, multi-channel exfiltration, bulletproof infrastructure

Credential Phishing • PhaaS • Multi-channel Exfil • Compromised Sites • Androxxgh0st • Bulletproof

Parameter	Value
Period	6–9 July 2026 (three waves)
Classification	Credential-harvesting phishing
Threat level	HIGH
Attribution	Shared phishing kit / PhaaS; delivery via KPROHOST bulletproof hosting (AS214940)
Target	Corporate mailboxes at a monitored domain (target details withheld)
Status	Campaign active; pages on compromised sites, exfiltration multi-channel

1. Executive Summary

Between 6 and 9 July 2026, corporate mailboxes at a monitored domain received at least three waves of phishing aimed at harvesting corporate email credentials. The waves share a common phishing kit (PhaaS): sender spoofing (first a brand, then the victim's own-domain administrator), an SPF failure, credential pages hosted on compromised legitimate sites, and payload links masked behind trusted redirects.

Key characteristics established by analyzing the retrieved payload: (1) the kit is polymorphic — at least two distinct client-side variants with different obfuscation were observed; (2) exfiltration of stolen data is multi-channel and rotates between builds — three independent channels are confirmed (the Formspark form service, a Telegram bot, and a PHP backend on a third-party domain); (3) delivery comes from a bulletproof-hosting cluster that also uses the same tooling (AndroXgh0st) to compromise the sites hosting the pages.

Practical implication: blocking a single exfiltration channel or URL does not stop credential collection — all channels must be closed simultaneously, with separate take-down/ban of the resources. This report is published so defenders can block the indicators and the owners of the compromised sites can remediate.

2. Wave overview

Feature	Wave 1 (6 Jul)	Wave 2 (7 Jul)	Wave 3 (9 Jul)
Lure	American Express KYC	Own-domain admin	Own-domain admin
Subject	"Reminder: action needed"	"Unrecognized Login"	"Account Locked"
Sender	78[.]130[.]245[.]134	77[.]83[.]39[.]10	77[.]83[.]39[.]10
Infrastructure	Compromised MikroTik	KPROHOST AS214940	KPROHOST AS214940
Link obfuscation	t.co	google.com/url	is.gd
Kit variant	Webmail harvester	Webmail harvester	cPanel/Roundcube clone
Exfil channel	Formspark	Formspark / Telegram	PHP backend

A mass-mailing tell was also recorded: the wave-3 short link's prefilled address belonged to a different, unrelated mailbox than the recipient — i.e. the same links are reused across victims.

3. Payload and phishing kit

The credential pages were retrieved (anonymously) and analyzed. They are static webmail clones (not AiTM / reverse-proxy). Two obfuscation variants were seen: (a) HTML assembled via `document.write(unescape('%XX...'))` — a "Webmail" variant; (b) a layered loader, `base64` → `atob` → `string-array` obfuscator (`javascript-obfuscator`) → `document.write` — a cPanel/Roundcube interface clone ("Orange Webmail").

In all variants the form has a read-only, prefilled email field and a password field; some versions implement a "double harvest" (the first submission feigns an error to filter out typos). After theft the user is redirected to the real domain of their address so the visit appears to complete normally. In one variant an open directory listing exposed the kit's internal PHP scaffold.

4. Multi-channel exfiltration (key finding)

Stolen username/password pairs do not go to a single destination. Analysis of different builds confirms three independent, rotating channels:

- The Formspark form service — a client-side fetch POST (JSON) to `hxxps://submit-form[.]com/<id>`; at least three rotating form IDs are used (4FJePSjAq confirmed).
- A Telegram bot — login and password sent directly to a bot (username MoneyMustbot) via `api.telegram.org`.
- A PHP backend on a third-party domain — `hxxps://qilu-pharma[.]store/files/steph/rundcub/main[.]php` (the Roundcube-clone variant).

Because the channel is chosen per build and rotates, disabling one does not stop collection. Response priority is to close all three channels at once (including reporting the Telegram bot to Telegram) and to block the kit asset host `mxhdjr[.]com`.

5. Infrastructure and attribution

- Wave 1 was sent from a compromised MikroTik router (residential address, Bulgaria).
- Waves 2–3 were sent from the KPROHOST LLC bulletproof host (AS214940, US, Frankfort KY; present on the Spamhaus ASN-DROP list).
- The hosting sites were compromised using AndroXgh0st, which exploits known vulnerabilities (all in the CISA KEV catalog): CVE-2017-9841 (PHPUnit RCE), CVE-2021-41773 (Apache path traversal), CVE-2018-15133 (Laravel APP_KEY / deserialization).
- The compromised sites are bona-fide victims; one was infected beyond a single path and served pages since 22 June, after which the original path began returning 404 (the kit was moved).

6. Indicators of Compromise (IOCs)

Values are defanged. Production-ready values are in the STIX 2.1 / MISP dumps.

Type	Value	Context
IP	78[.]130[.]245[.]134	Compromised MikroTik, Bulgaria (Coolbox); AbuseIPDB 47. Wave-1 sender.
IP	77[.]83[.]39[.]10	KPROHOST AS214940, bulletproof; AbuseIPDB 100. Wave 2–3 sender.
ASN	AS214940	KPROHOST LLC (US); bulletproof, Spamhaus ASN-DROP.
URL	hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html	Harvest page (compromised WordPress).
URL	hxxps://habitatcyprus[.]com/wp-includes/build/	Harvest page (compromised WordPress; path later 404).
URL	hxxps://lavilifescience[.]com/authn/mail/login[.]html	Harvest page (compromised site).
URL	hxxps://transtecexpress[.]com[.]br/sddcc/secure[.]html	Wave-3 harvest page (Roundcube clone).
URL (exfil)	hxxps://submit-form[.]com/4FJePSjAq	Formspark; ≥3 rotating form IDs. Take-down target.
URL (exfil)	hxxps://qilu-pharma[.]store/files/steph/rundcub/main[.]php	PHP credential backend. Take-down target.
Telegram	bot MoneyMustbot	Direct login/password exfil to Telegram. Report to Telegram.
Host	mxhdjr[.]com	Kit asset/staging host ("webmailorange").
Redirect	hxxps://t[.]co/... , google[.]com/url?q= , hxxps://is[.]gd/...	Payload-link masking; do not block the redirect domains wholesale.

6.1. MITRE ATT&CK

- T1566.002 — Phishing: Spearphishing Link
- T1656 — Impersonation
- T1190 — Exploit Public-Facing Application (Androxgh0st)
- T1584.004 — Compromise Infrastructure: Server

7. Recommendations

- Close ALL exfiltration channels at once: Formspark forms, the qilu-pharma PHP backend, and the Telegram bot (report to Telegram) — blocking one channel is ineffective.
- Block the sending IPs and AS214940 (KPROHOST) at the mail gateway; block the specific malicious URLs and the asset host mxhdjr[.]com.
- For compromised legitimate sites, block by URL not domain; notify the owners (check for Androxgh0st, patch CVE-2017-9841 / CVE-2021-41773 / CVE-2018-15133).
- Flag inbound mail where From uses your own domain but the message arrived externally and failed SPF/DKIM/DMARC.
- Deploy phishing-resistant MFA (FIDO2); train users not to enter credentials via links in email.

TLP:CLEAR — This document may be distributed without restriction.